

XXVI SIMPÓSIO BRASILEIRO DE CIBERSEGURANÇA · SBSEG 2026

1 a 4 de setembro de 2026 · Armação dos Búzios, RJ

Local vs. Nuvem: LLMs locais para extração de vulnerabilidades de relatórios de scanners de segurança



Beatriz Machado, Cristhian Kapelinski e Diego Kreutz

AI Horizon Labs · Universidade Federal do Pampa (UNIPAMPA)

Programa de Pós-Graduação em Engenharia de Software (PPGES)

ABERTURA

O acervo cresce, a triagem não acompanha



Scanners geram PDFs

CSIRTs varrem as aplicações, e cada varredura vira um relatório.

Leitura manual

Sem dado estruturado, a análise exige leitura de cada relatório.

Triagem atrasada

Sem consulta e priorização, a resposta demora.

ABERTURA

O dado não pode sair da organização

Já é viável

A ferramenta extrai bem, mas só foi testada em nuvem.

O impasse

Usar a nuvem é enviar a superfície de ataque a um terceiro.

A LGPD

Exige proteger a infraestrutura que trata dados pessoais (art. 46).

ARTIGO TRILHA PRINCIPAL



ABERTURA

Por que é difícil sem a nuvem

1 Modelos menores

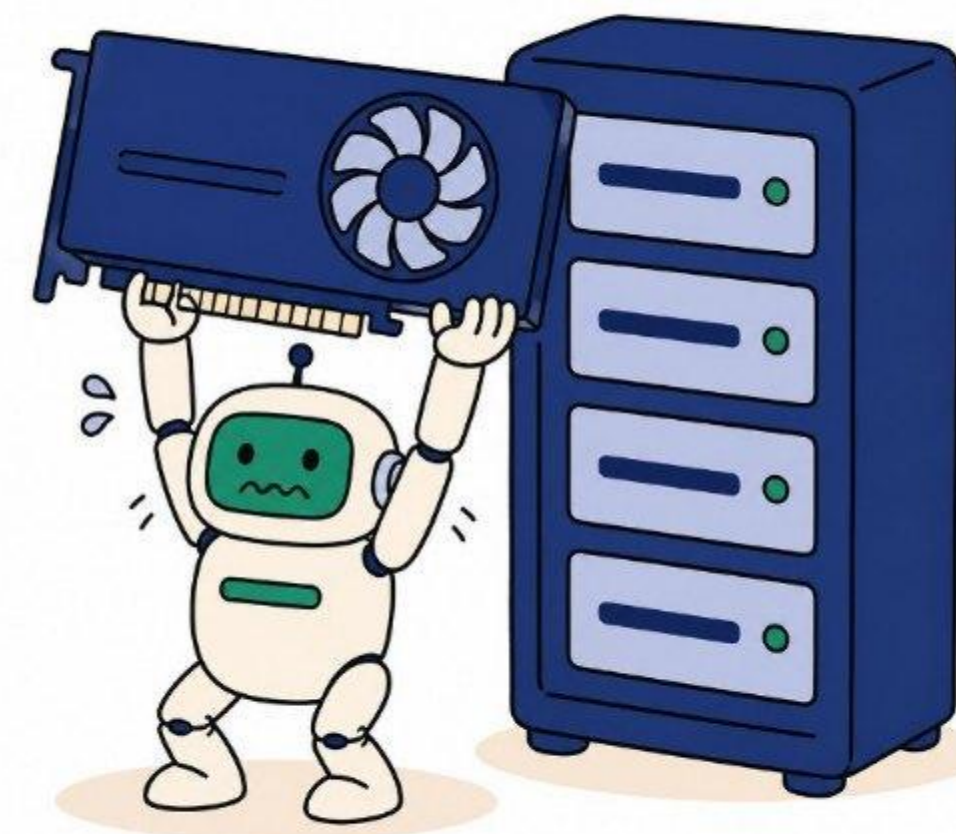
4B a 21B contra 284B da nuvem, com menos contexto.

2 Treinar é custoso

Fine-tuning na tarefa exige dados anotados e GPU para treinar.

3 Infraestrutura própria

GPU, VRAM e tempo de processamento passam a ser seus.



ABERTURA

O que já existe e o que falta

Trabalho	Tarefa	Modelos	Local vs. nuvem
Rahman et al. 2024	CTI → técnicas ATT&CK	1	Encoder local
Yang et al. 2026	CTI → grafo de conhecimento	1	Só nuvem
Wiest et al. 2023	Texto médico → tabelas	1	Só local
Keltek et al. 2024	Código-fonte → análise estática	1	Só local
Machado et al. 2025–26	Relatórios de scanner → registros	5	Só nuvem
Este trabalho	Relatórios de scanner → registros	10	Sim

Analisa código-fonte proprietário com **Llama-3 local**, por isso não pode usar nuvem. Mas **nunca compara com nuvem**: não mede o custo da escolha.

Trabalho	Tarefa	Modelos	Local vs. nuvem
Rahman et al. 2024	CTI → técnicas ATT&CK	1	Encoder local
Yang et al. 2026	CTI → grafo de conhecimento	1	Só nuvem
Wiest et al. 2023	Texto médico → tabelas	1	Só local
Keltek et al. 2024	Código-fonte → análise estática	1	Só local
Machado et al. 2025–26	Relatórios de scanner → registros	5	Só nuvem
Este trabalho	Relatórios de scanner → registros	10	Sim

Pipeline de extração

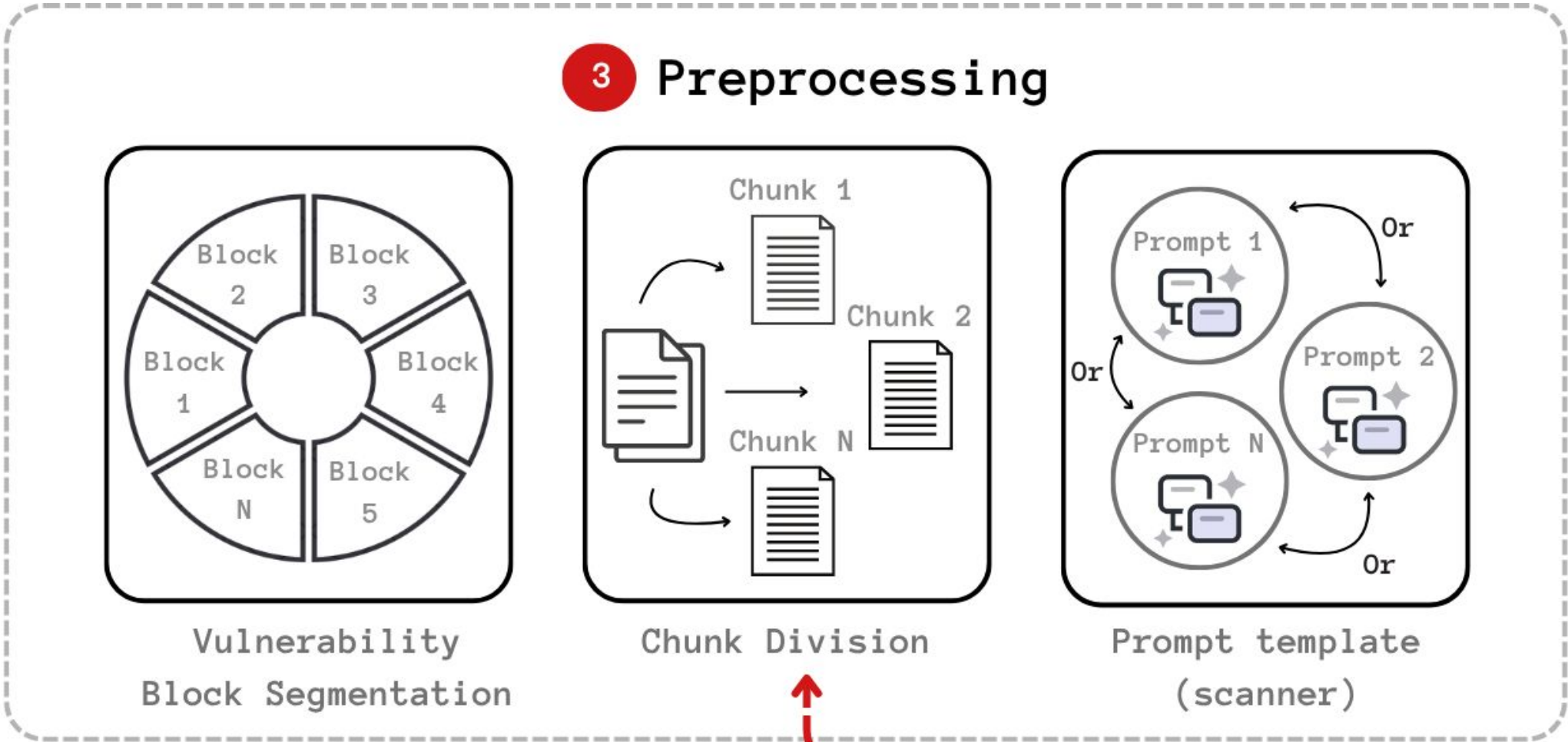
2 Text extraction



1 Input Data



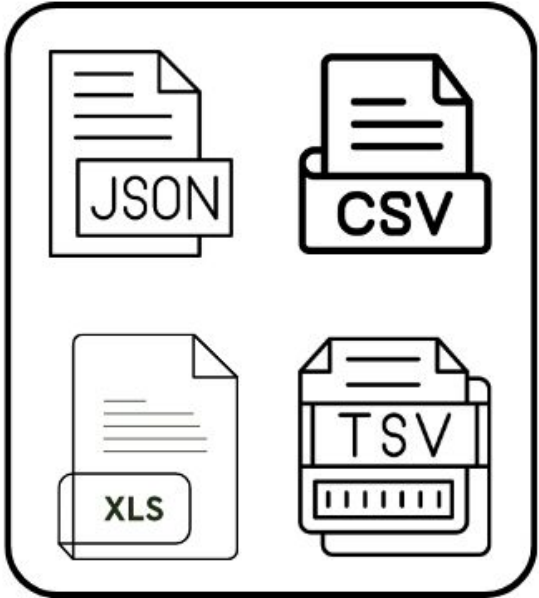
3 Preprocessing



6 Analysis



5 Output



4 LLMs



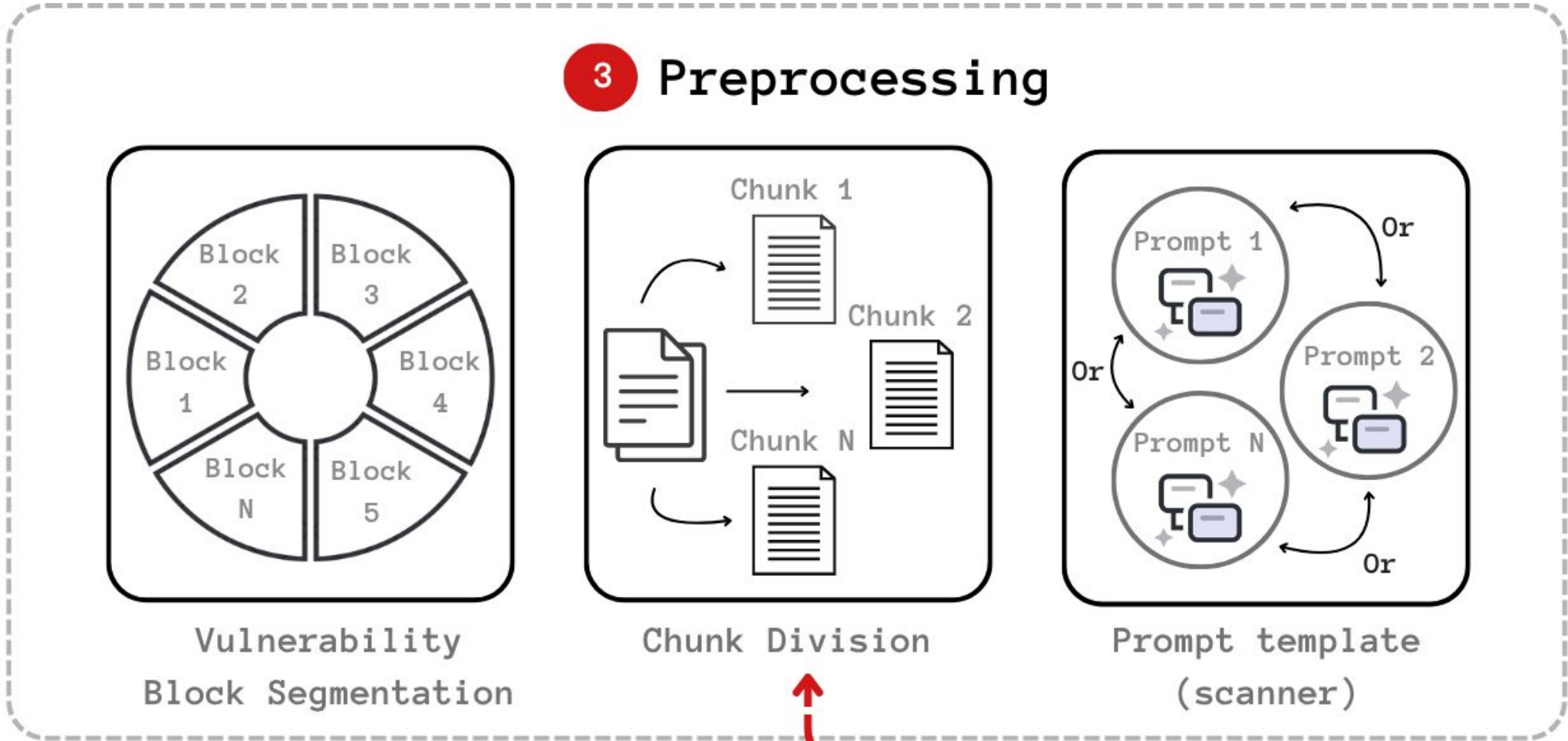
Retry if needed

Etapa 1: dados de entrada

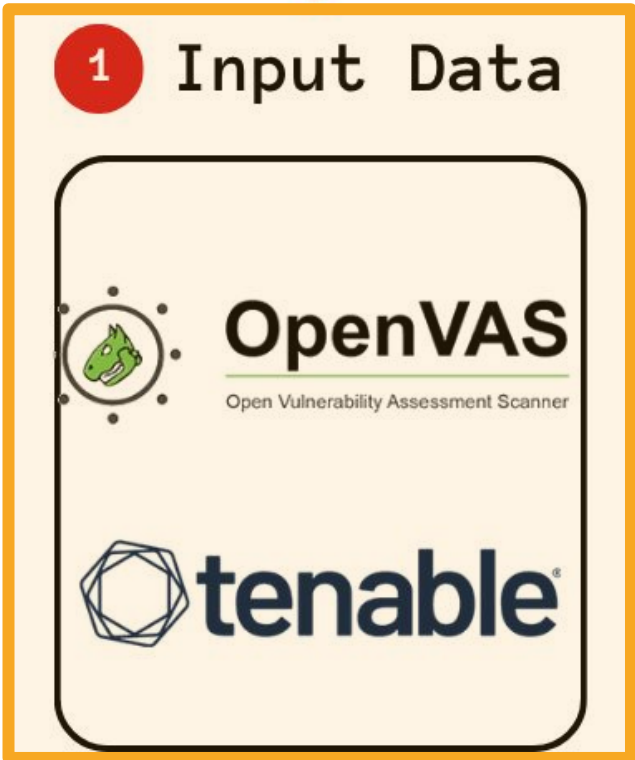
2 Text extraction



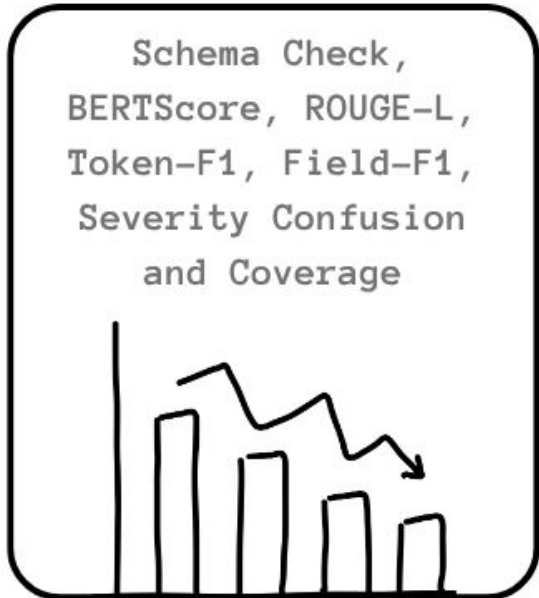
3 Preprocessing



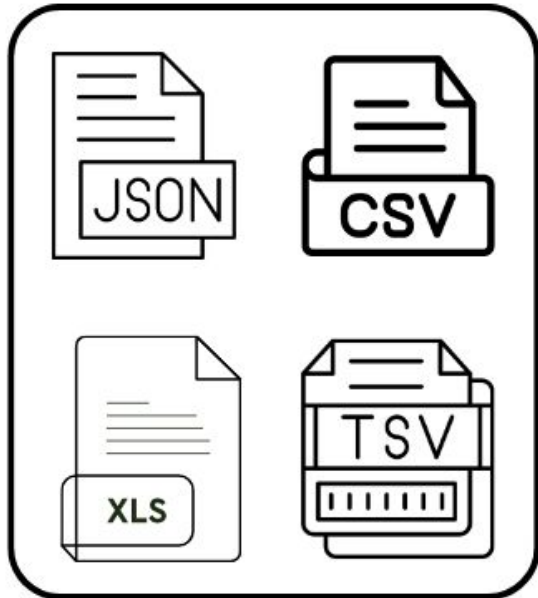
1 Input Data



6 Analysis



5 Output



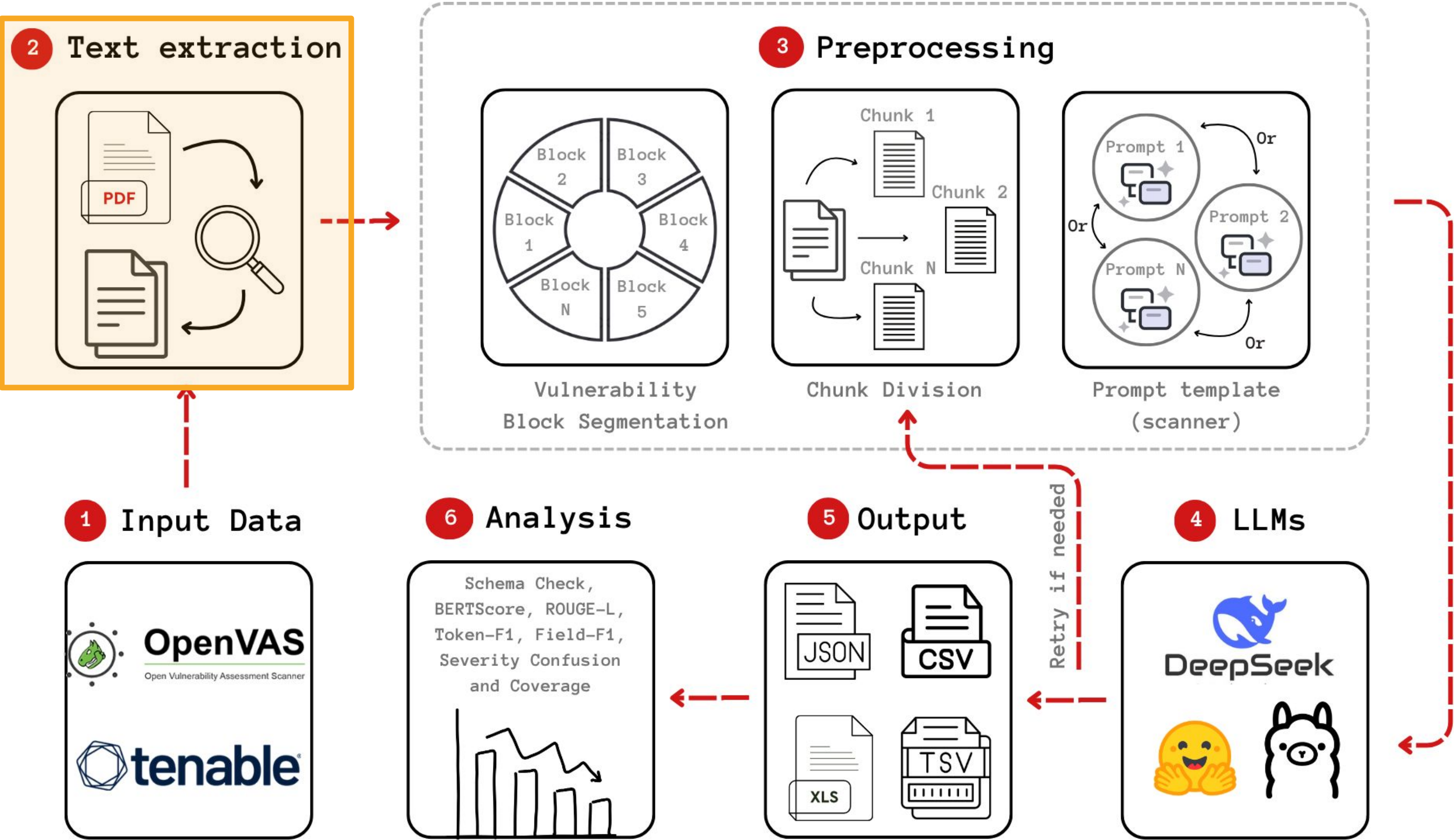
4 LLMs



Retry if needed



Etapa 2: extração de texto



Etapa 3: pré-processamento

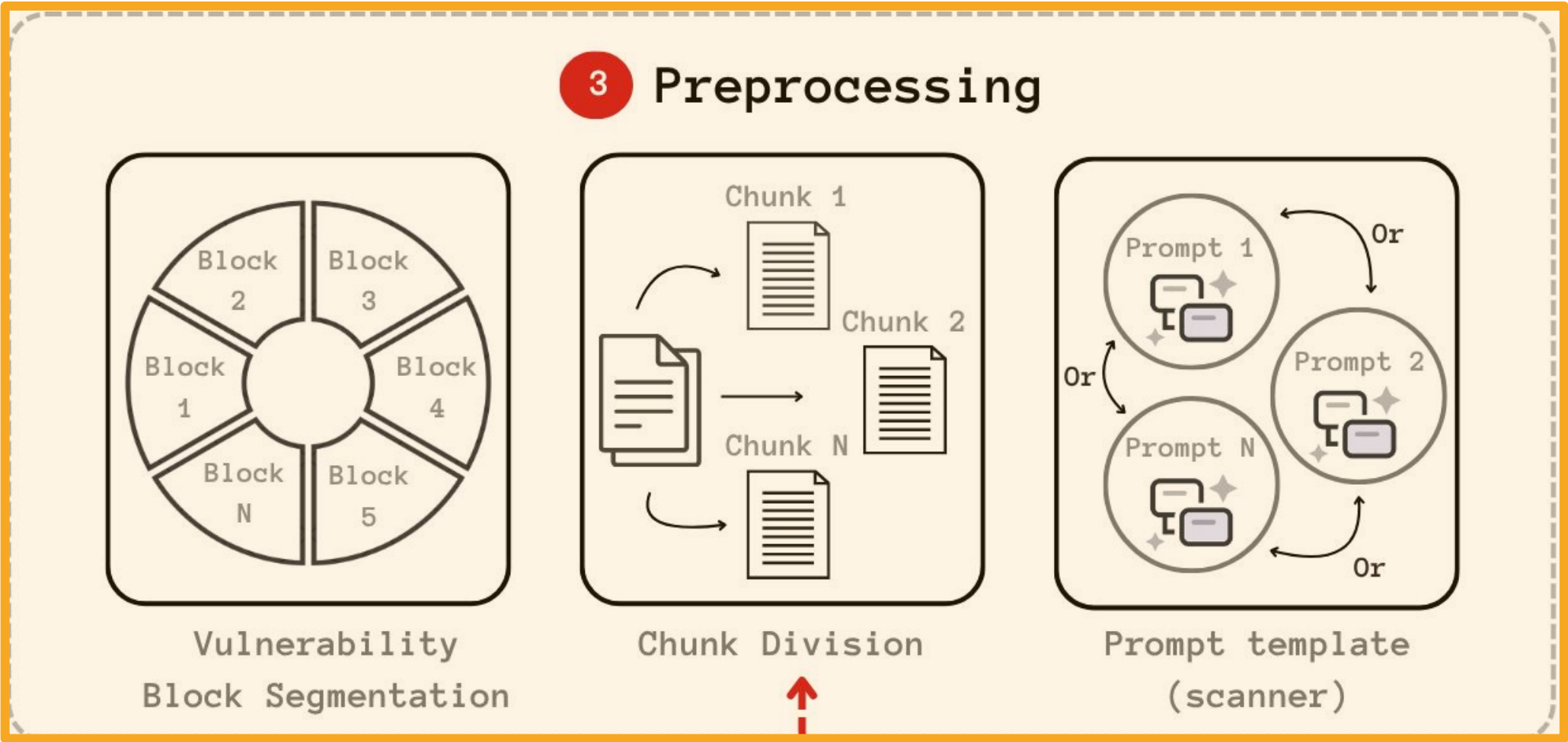
2 Text extraction



1 Input Data



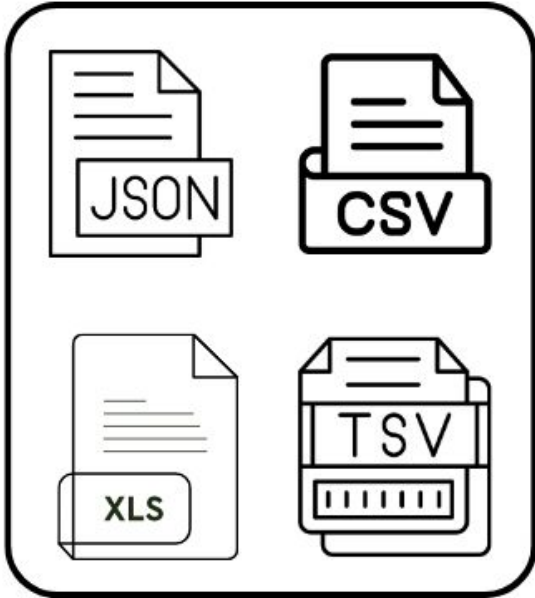
3 Preprocessing



6 Analysis



5 Output



4 LLMs



Retry if needed

Etapa 4: o modelo, nuvem ou local

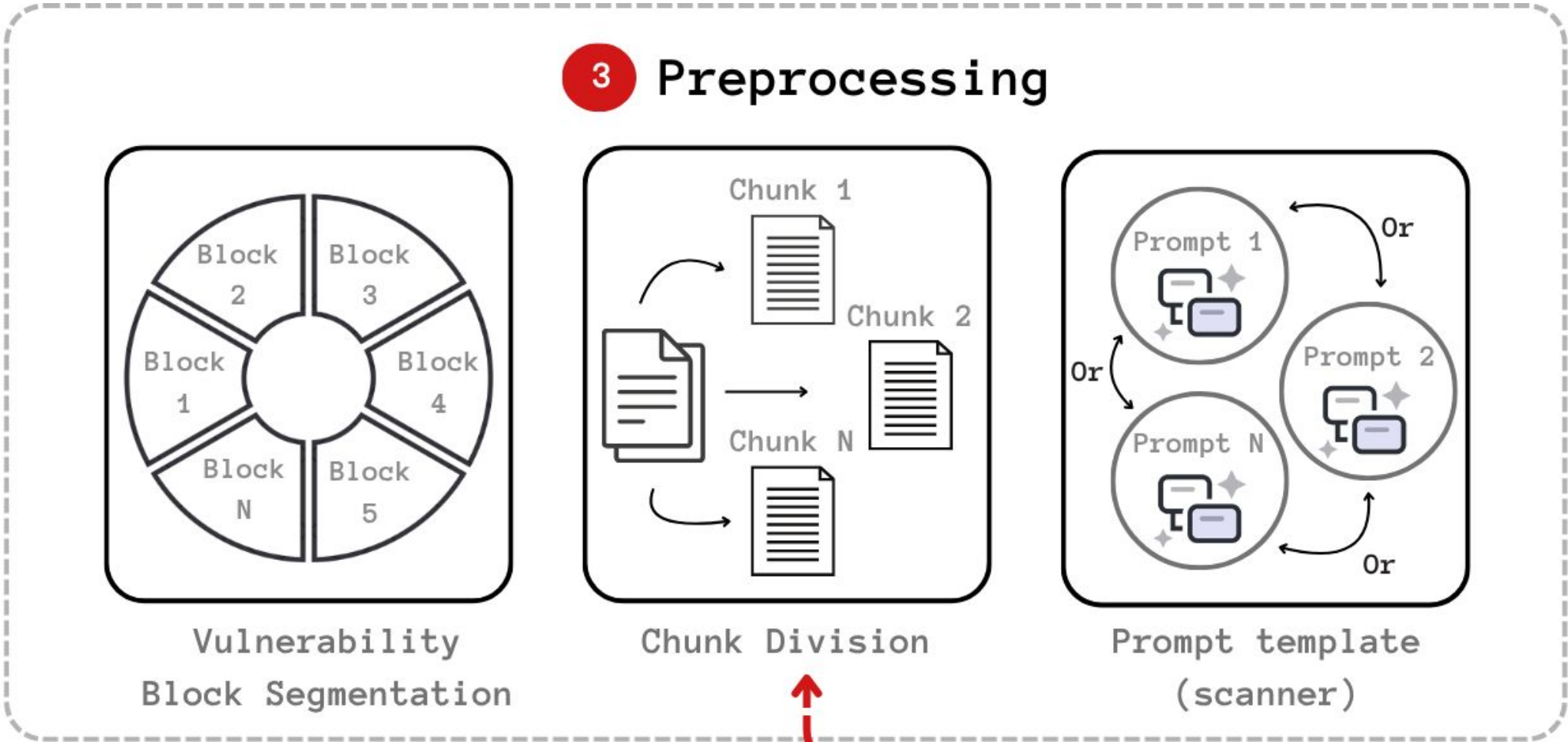
2 Text extraction



1 Input Data



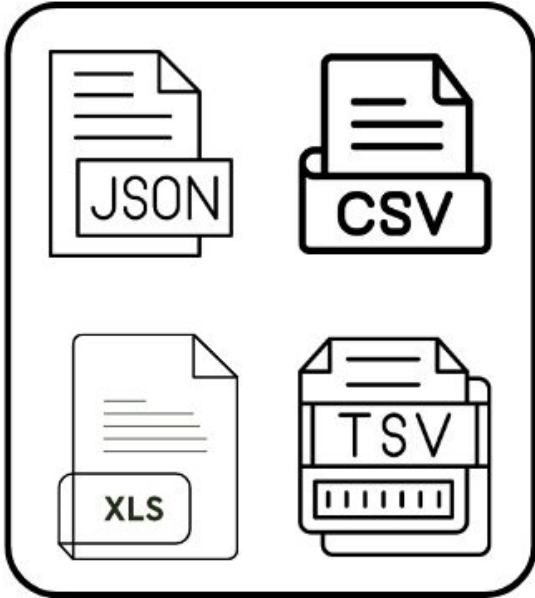
3 Preprocessing



6 Analysis



5 Output



4 LLMs



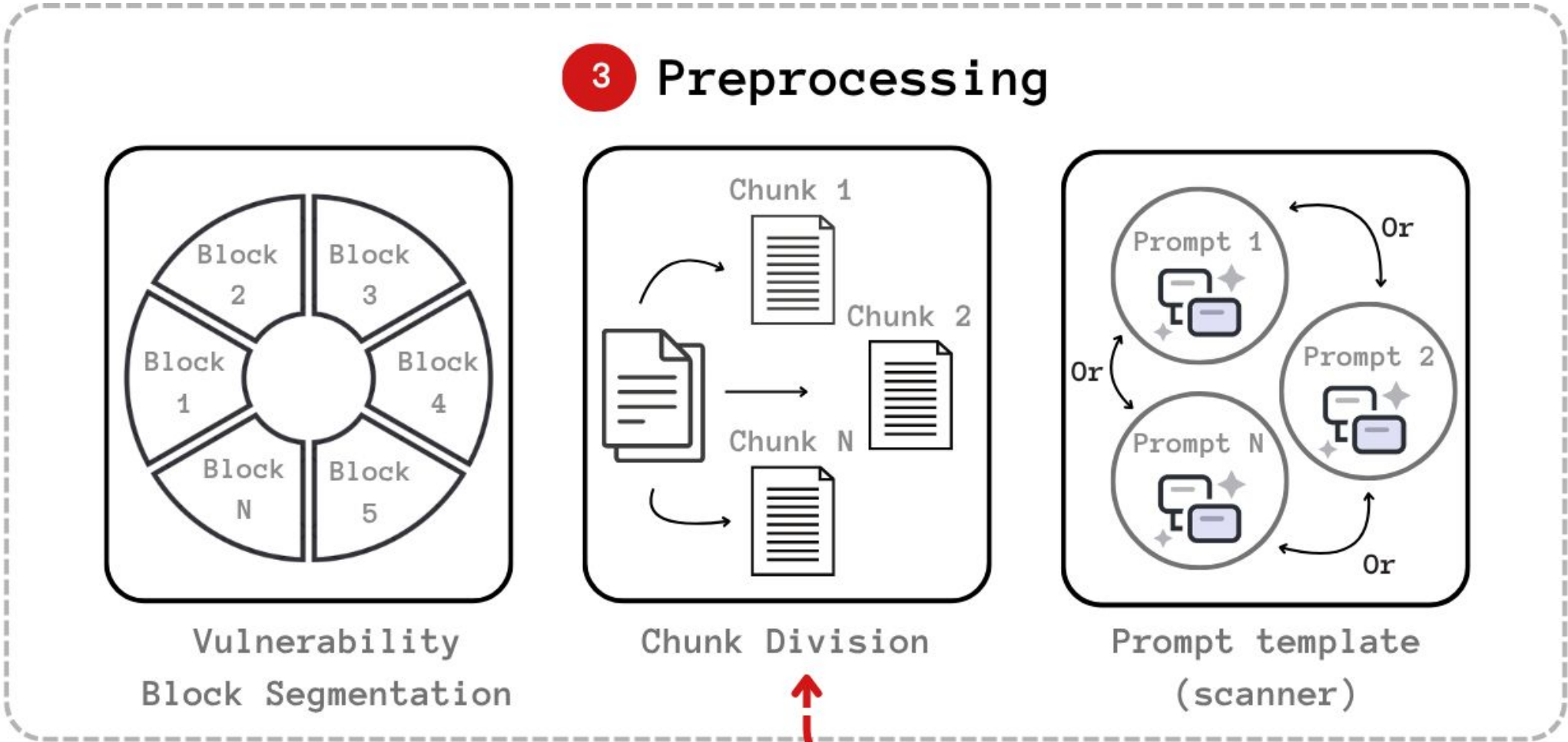
Retry if needed

Etapa 5: saída estruturada

2 Text extraction



3 Preprocessing



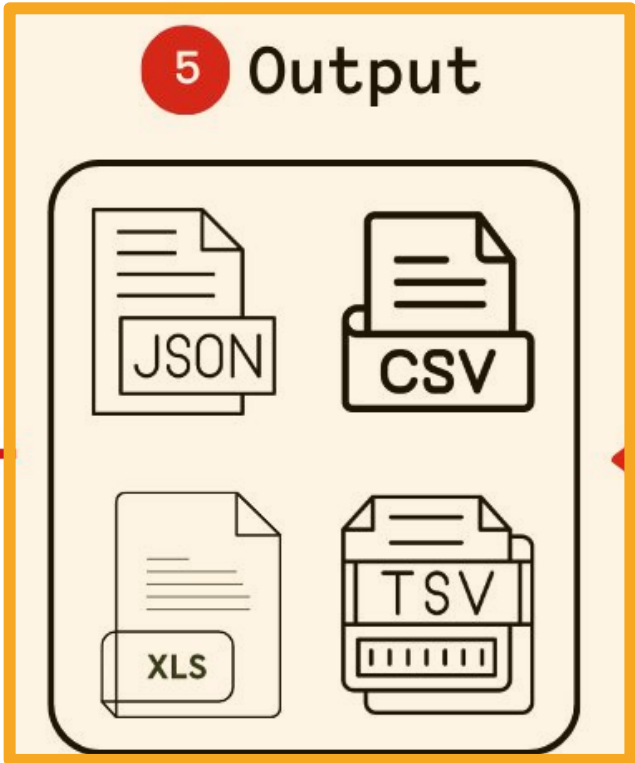
1 Input Data



6 Analysis



5 Output



4 LLMs



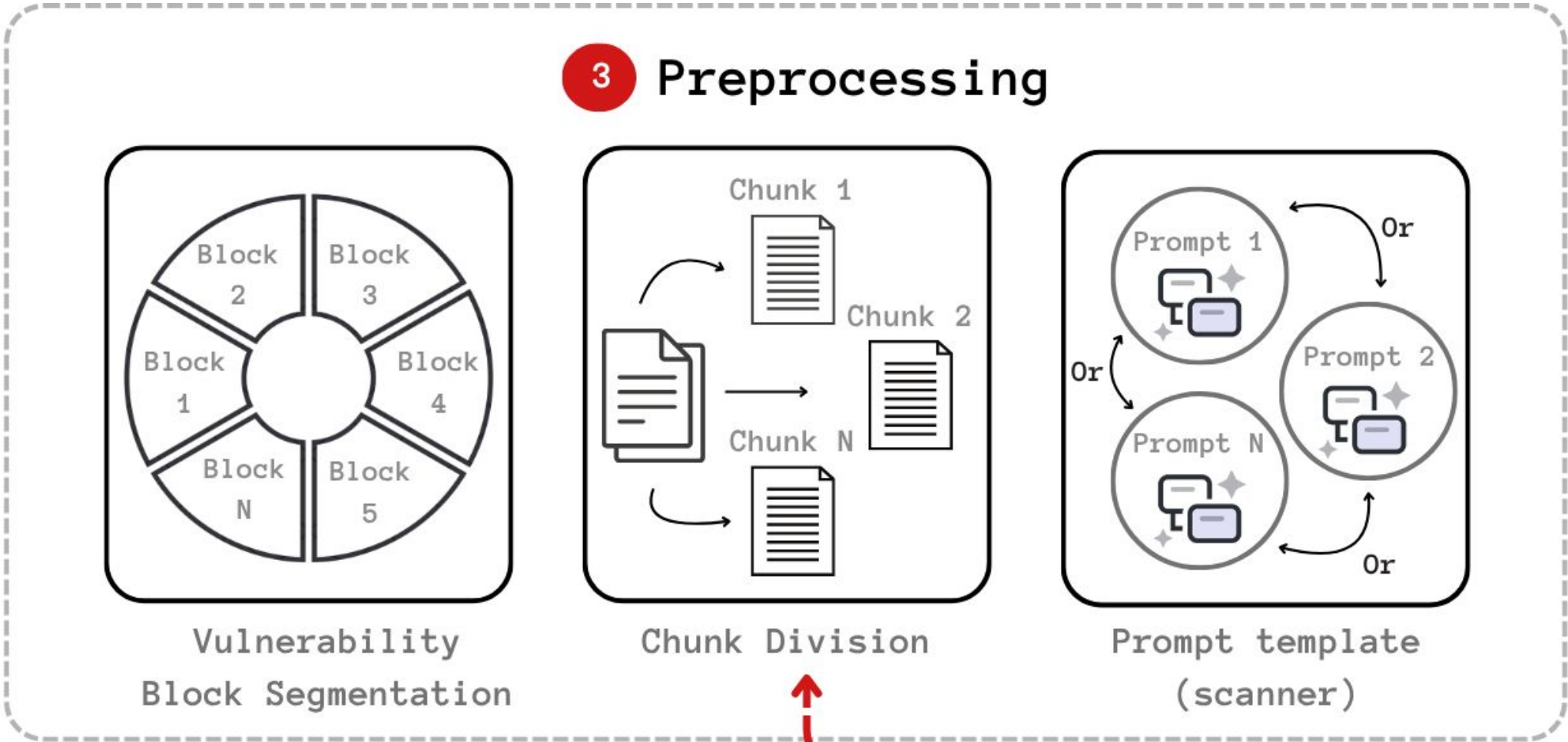
Retry if needed

Etapas 6: análise

2 Text extraction



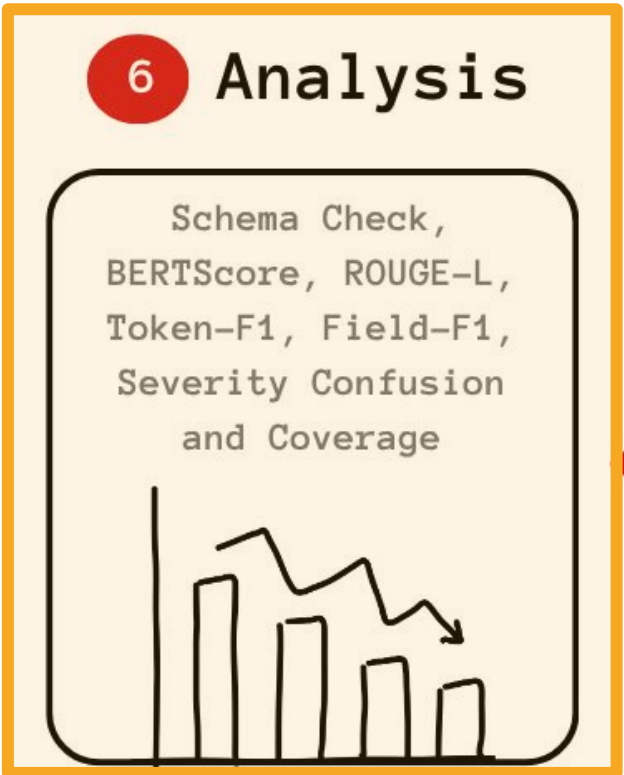
3 Preprocessing



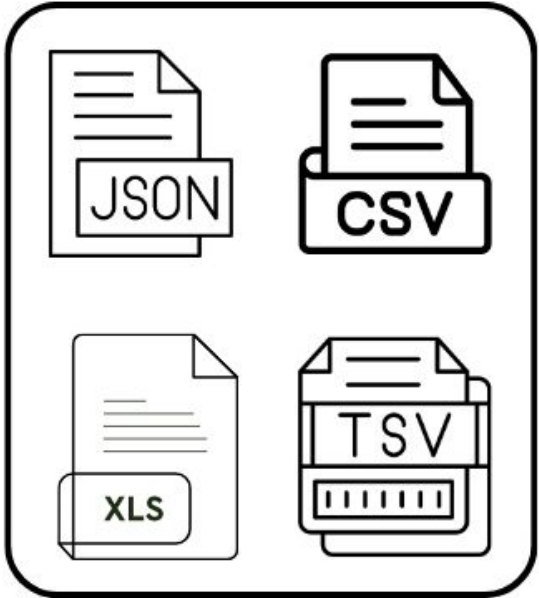
1 Input Data



6 Analysis



5 Output



4 LLMs



Retry if needed



01 · ABORDAGEM

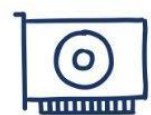
Desenho experimental

**208**

vulnerabilidades em 3
baselines, validadas por 2
especialistas

**10**

modelos: 9 locais (4B–21B)
+ nuvem, com 2 fine-tunes
de segurança

**2**

GPUs de consumidor:
RTX 3060 (12 GB) e RTX
5080 (16 GB)

**5×**

execuções por par
modelo–baseline, com IC
de 95%

Métricas de avaliação

BERTScore fidelidade dos campos narrativos `insight, log_method`

Field-F1 acerto exato dos campos determinísticos `cvss: 7.5`
`port: 443`

Cobertura registro omitido ou inventado `omissão = 1 - recall`

Schema registro conforma ao esquema JSON `valida / não valida`

Severidade macro-F1 por classe de severidade `low ... critical`

02 · RESULTADOS

O melhor local fica a 1,2 ponto da nuvem

Modelo	BERTScore	Field F1	Schema
Ministral 3 (8B)	93,0	98,4	96,0
gpt-oss (21B)	91,1	98,5	99,8
Phi-4 (14B)	91,0	98,8	100,0
Llama 3.1 (8B)	85,5	95,6	99,1
Foundation-Sec (8B)	78,8	97,8	82,1
Primus-Merged (8B)	85,2	96,8	99,5
deepseek-v4-flash (nuvem)	94,2	99,0	100,0

1,2 pp

é o gap do melhor local para a nuvem em texto livre (IC 95% [0,2 – 2,1])

14 pp

é a dispersão entre o melhor e o pior modelo local

Verde: melhor valor entre os locais em cada coluna

02 - RESULTADOS

O melhor local fica a 1,2 ponto da nuvem

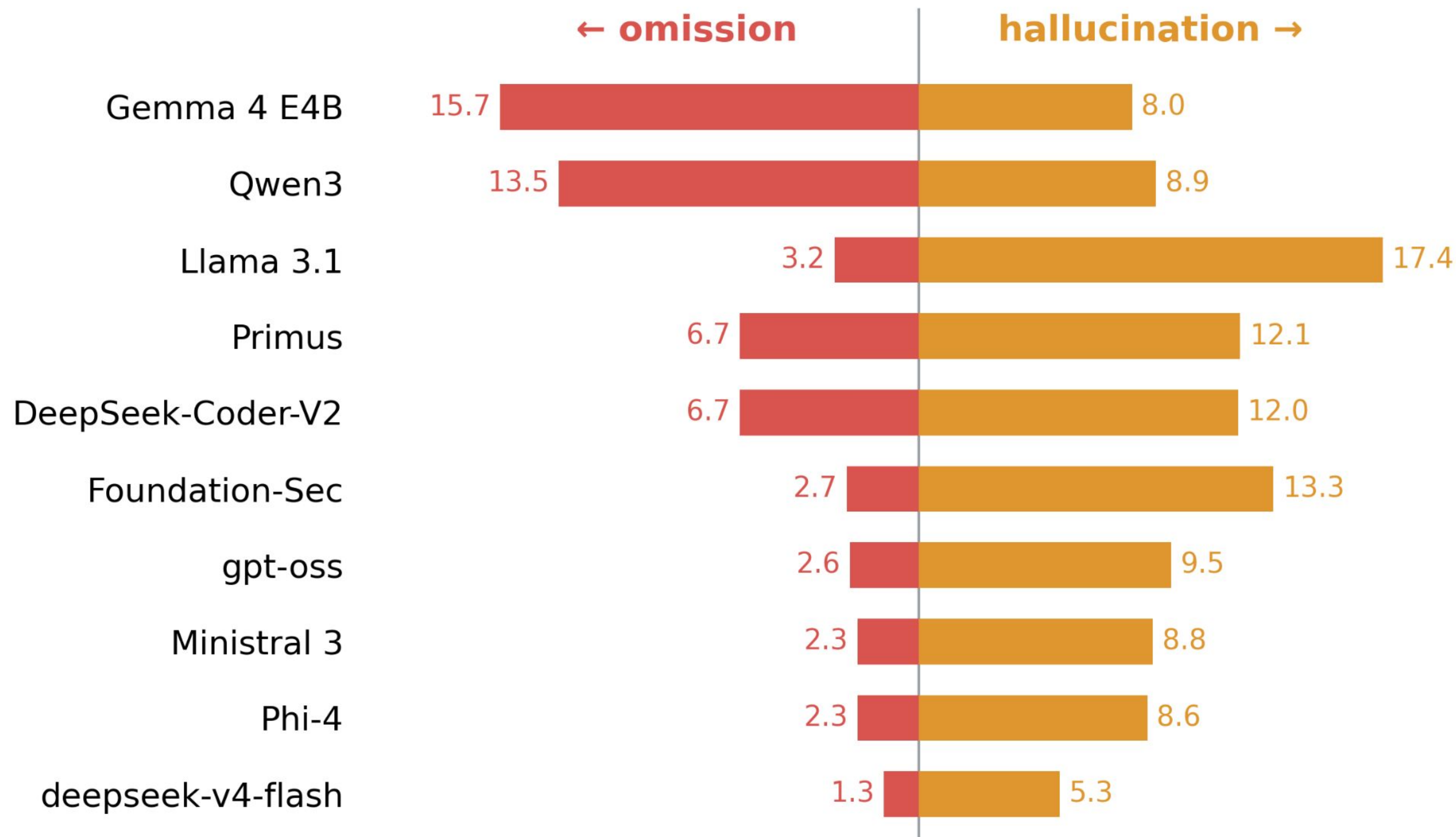
Modelo	BERTScore	Field F1	Schema
Ministral 3 (8B)	93,0	98,4	96,0
gpt-oss (21B)	91,1	98,5	99,8
Phi-4 (14B)	91,0	98,8	100,0
Llama 3.1 (8B)	85,5	95,6	99,1
Foundation-Sec (8B)	78,8	97,8	82,1
Primus-Merged (8B)	85,2	96,8	99,5
deepseek-v4-flash (nuvem)	94,2	99,0	100,0

Modelo utilizado por **Keltek et al. 2024**

Verde: melhor valor entre os locais em cada coluna

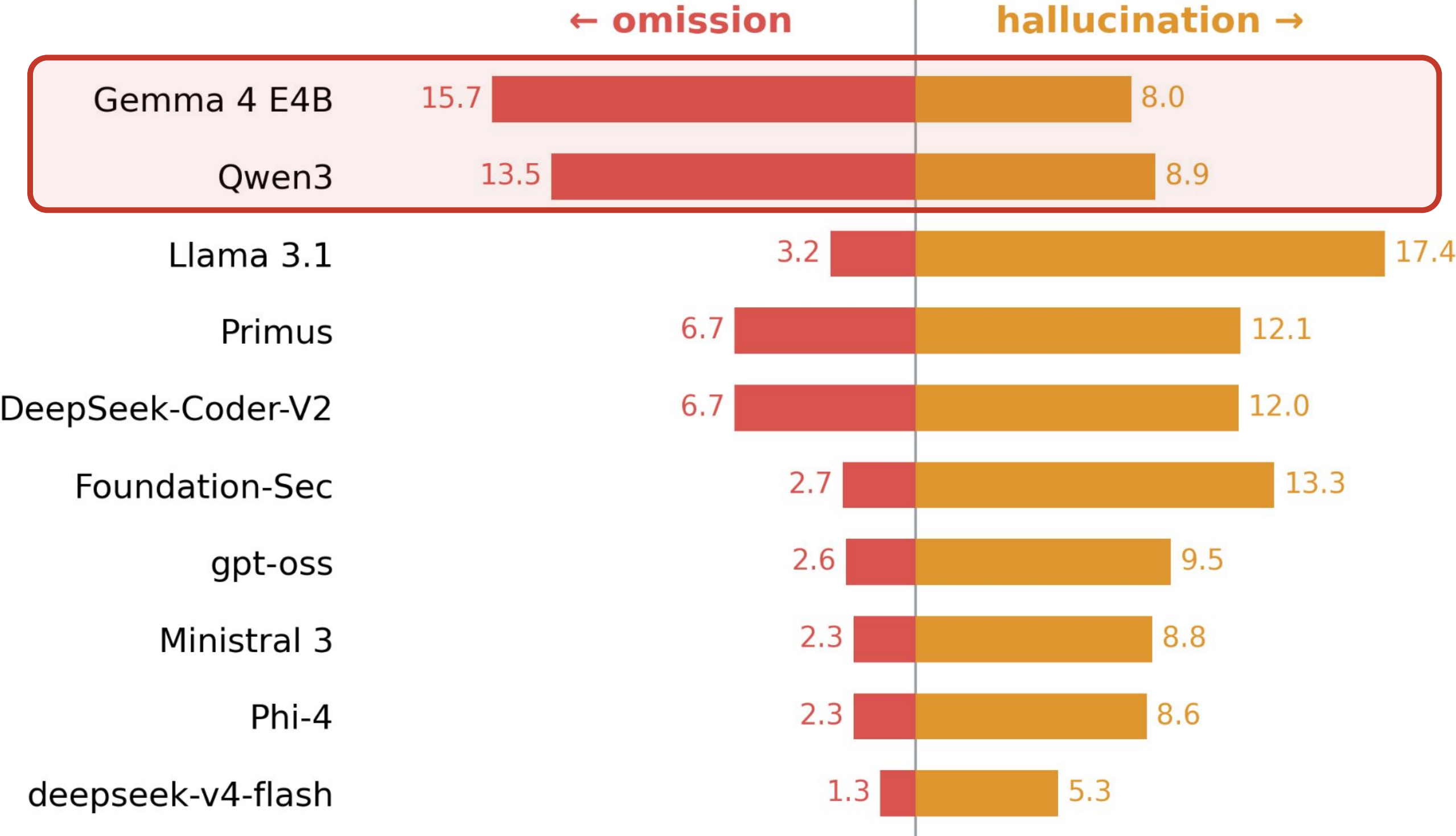
Dois modos de falha, riscos diferentes

Per-model trade-off: omission vs. hallucination (per vulnerability)



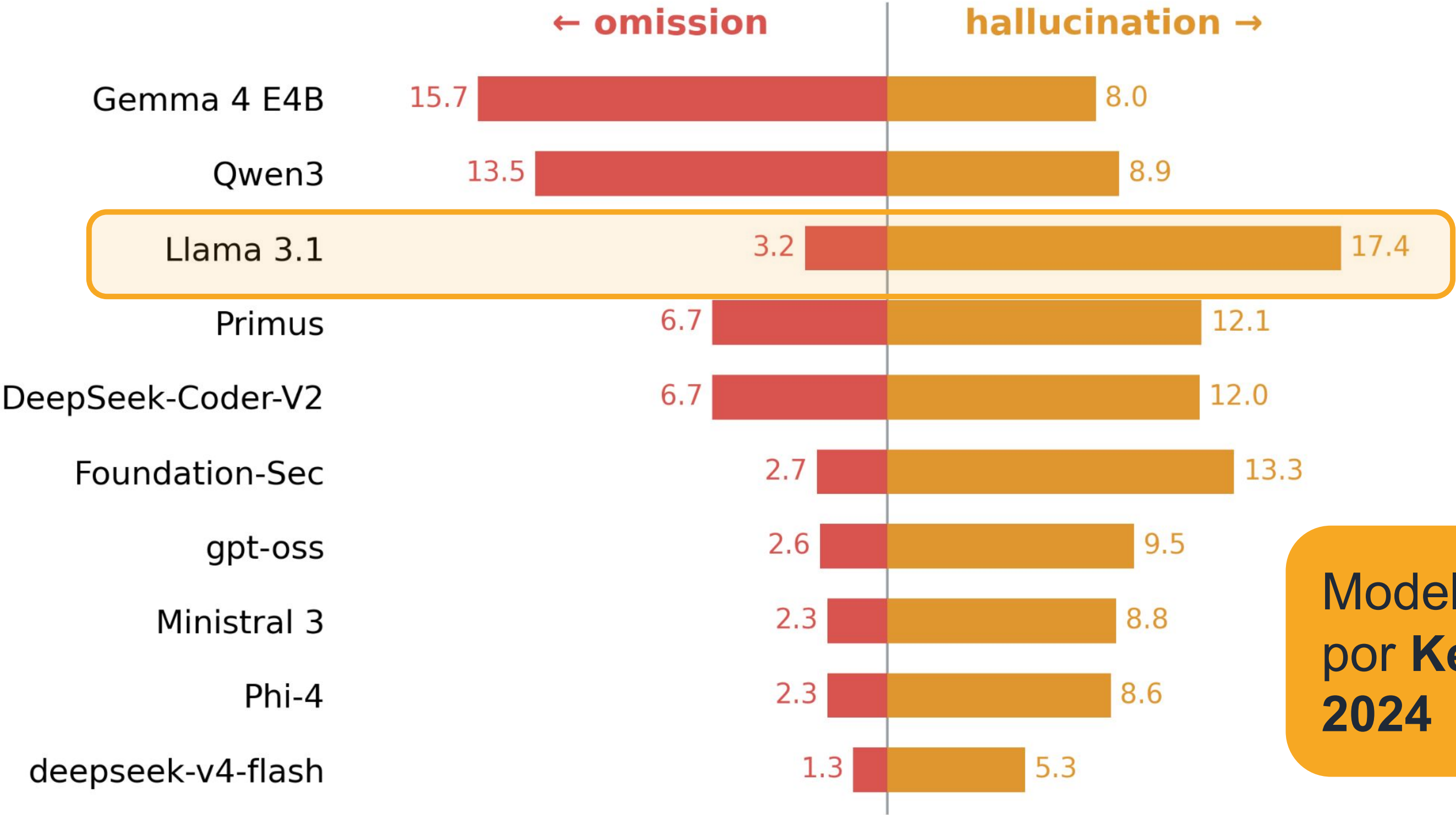
Gemma 4 omite 15,7% das vulnerabilidades e Qwen3, 13,5%: o registro nunca chega à base.

Per-model trade-off: omission vs. hallucination (per vulnerability)



Llama 3.1 quase não omite, mas inventa **17,4%** dos registros.

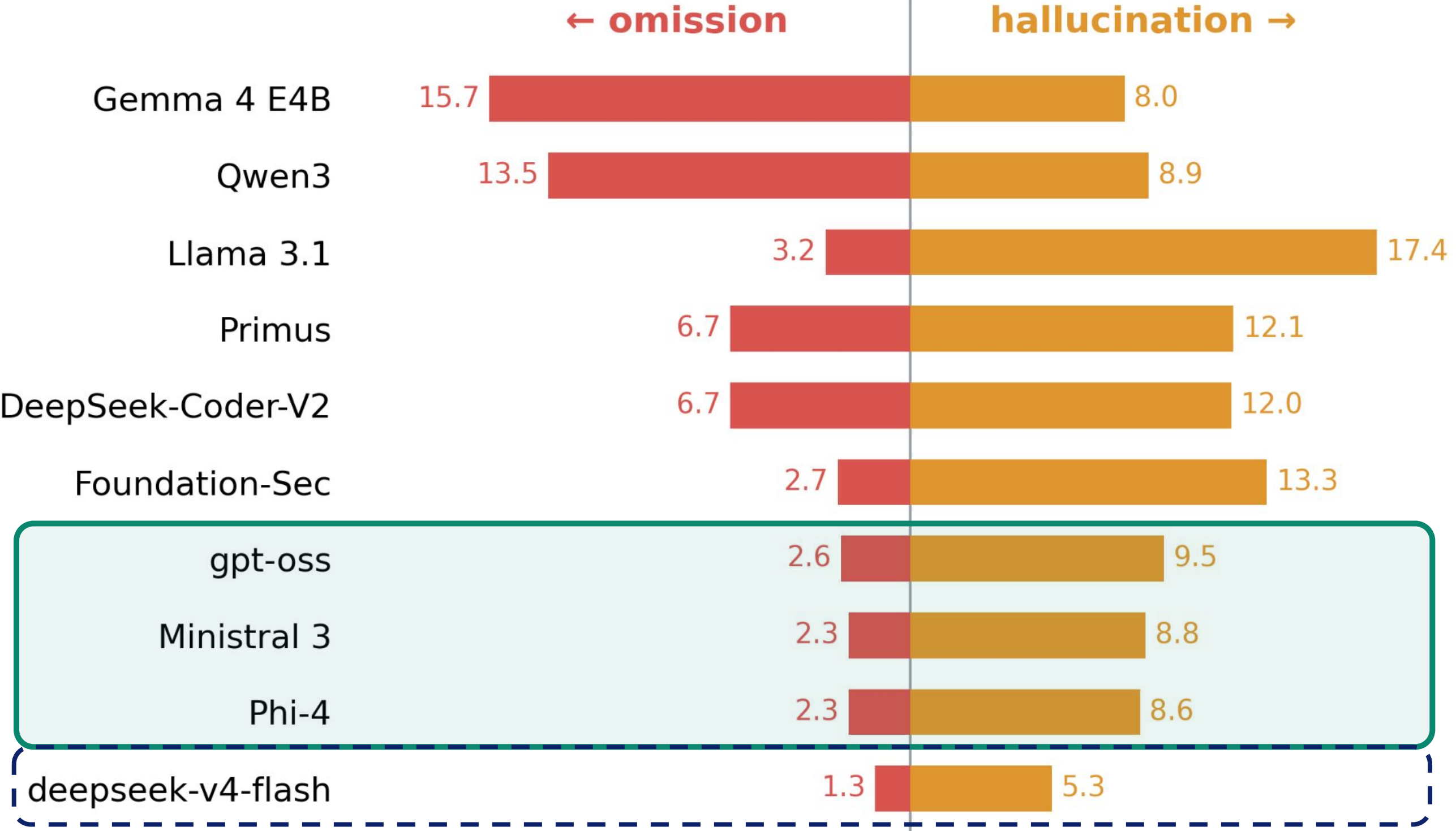
Per-model trade-off: omission vs. hallucination (per vulnerability)



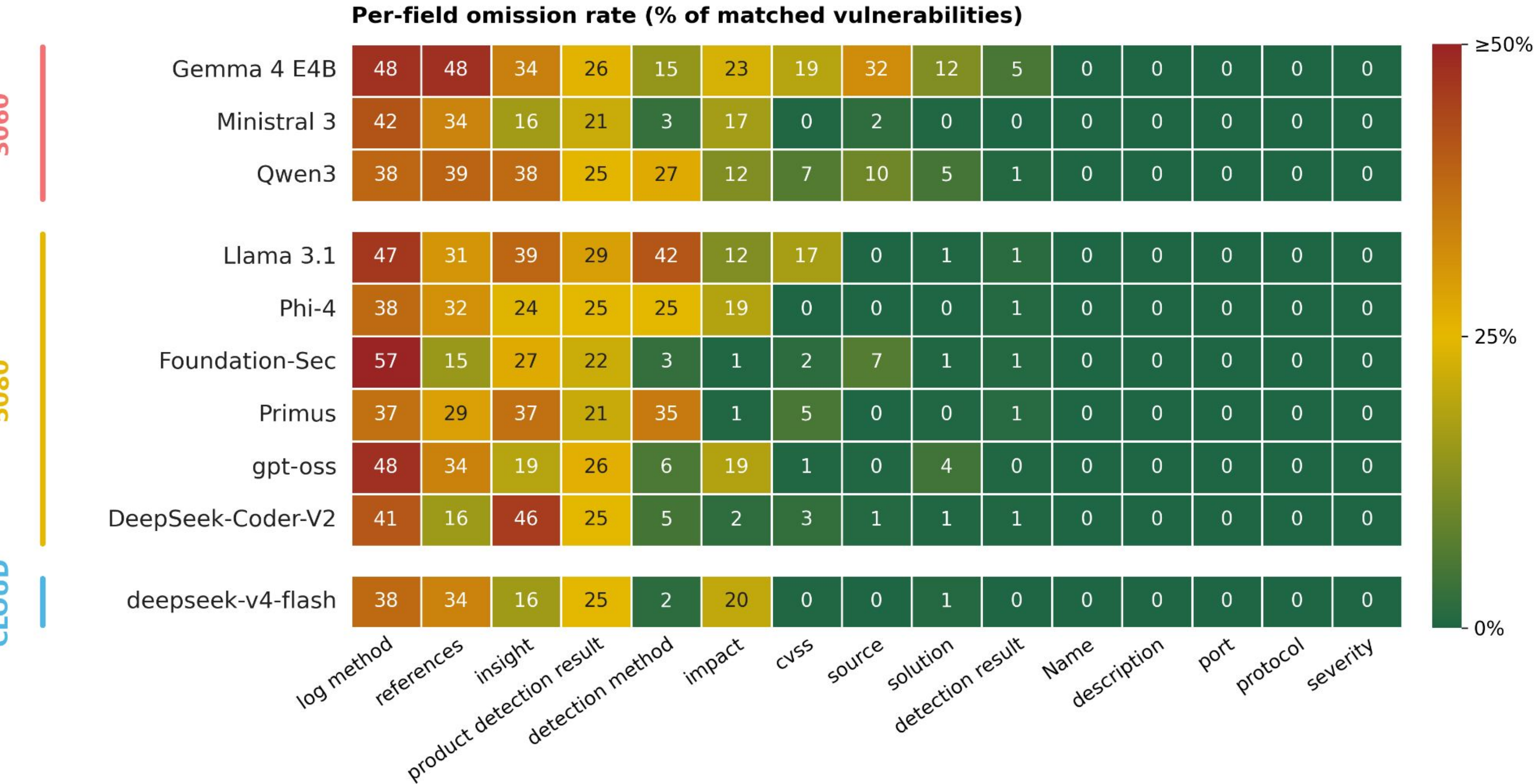
Modelo utilizado por **Keltek et al. 2024**

gpt-oss, Ministral 3 e Phi-4 mantêm os dois baixos: 2,3% a 2,6% de omissão, contra 1,3% da nuvem.

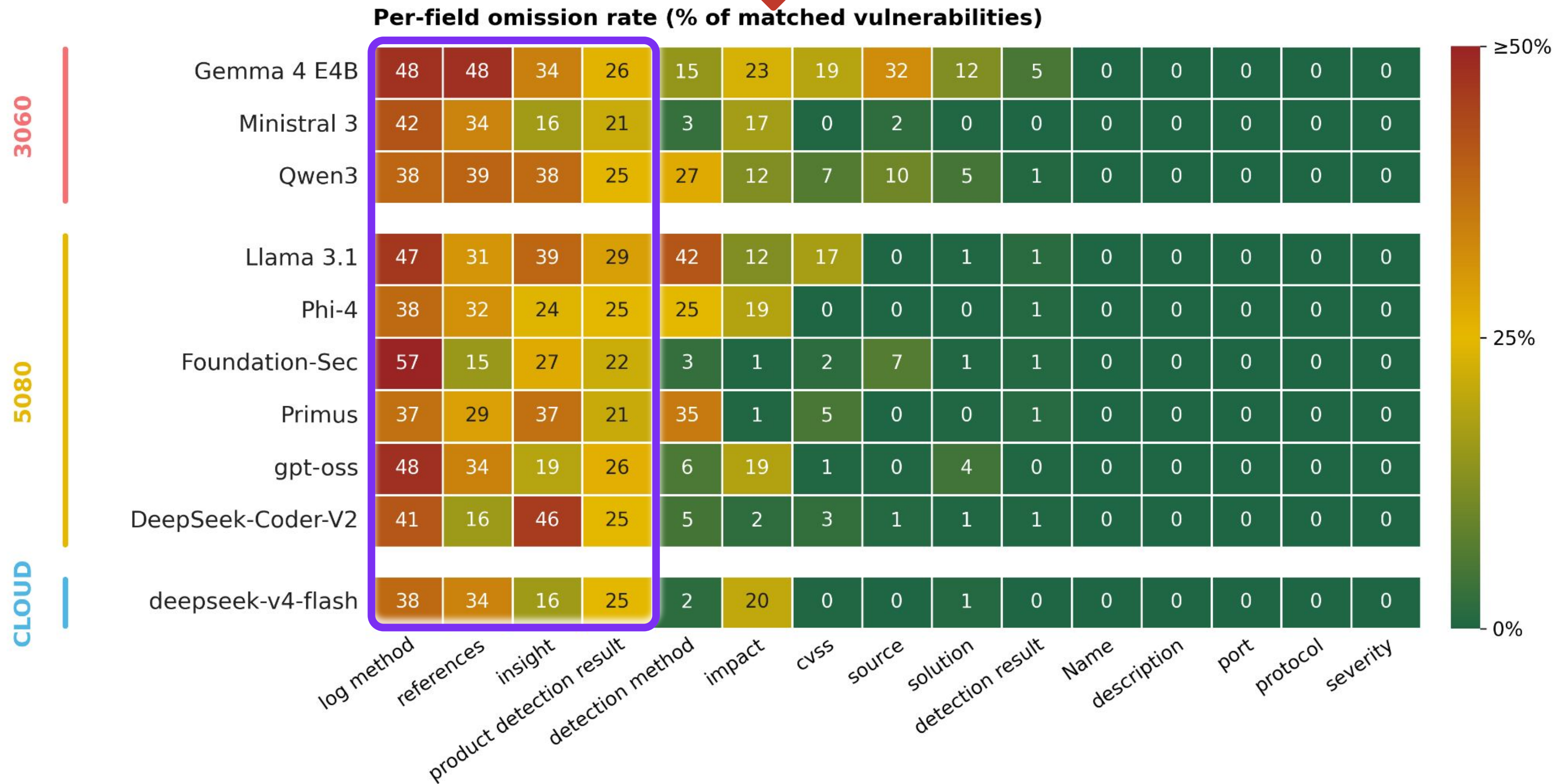
Per-model trade-off: omission vs. hallucination (per vulnerability)



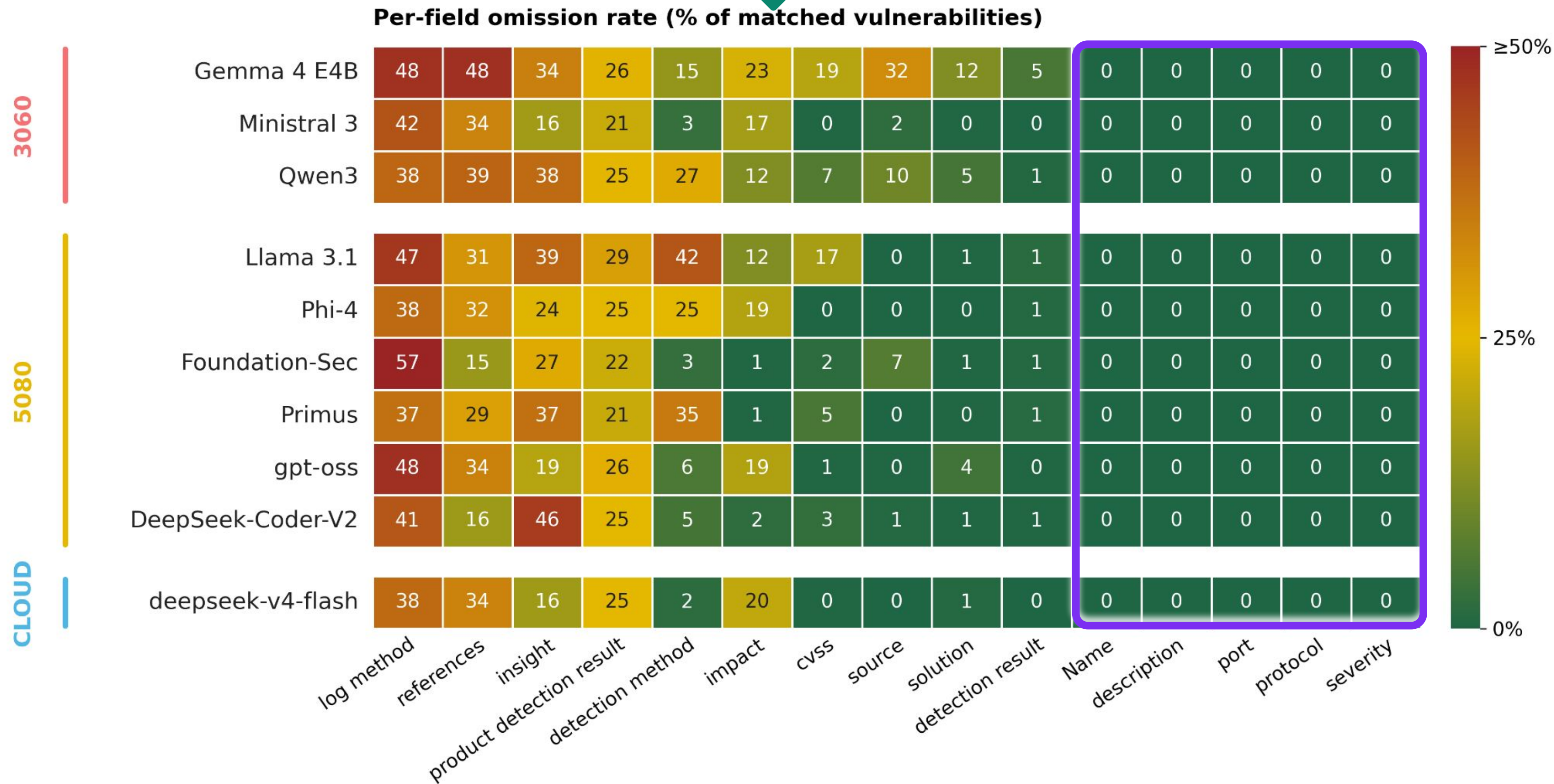
O gap se concentra nos campos narrativos



Os campos narrativos são omitidos por todos, inclusive pela nuvem: é limite da tarefa, não do modelo local.



Descrição, porta, protocolo e severidade: zero de omissão em todos os modelos, do 4B à nuvem.



03 · CONCLUSÕES

Considerações finais

1,2_{pp}

Viável

É tudo o que separa o melhor local da nuvem em texto livre. Campos estruturados empatam.

14_{pp}

Escolher pesa mais

A dispersão entre os locais é 12 vezes o gap para a nuvem.

0

Relatório exposto

Sob a LGPD, on-premise não é só viável: é preferível.

03 · CONCLUSÕES

Trabalhos futuros

Mais escopo

Outros scanners, formatos e relatórios maiores.

Prompting por campo

Atacar os campos narrativos sem trocar de modelo.

Arquitetura dos modelos

Entender como as diferenças estruturais dos modelos locais afetam a extração.

Extração com RAG

Ancorar os campos narrativos numa base vetorial da NVD.

Obrigada!

Perguntas são bem-vindas

AUTORA DE CONTATO

Beatriz Machado

beatrizmachado.aluno@unipampa.edu.br

AI Horizon Labs · UNIPAMPA · PPGES



AI Horizon Labs



Repositório

RESERVA

References

34–48% omitido

References

```
cve: CVE-2023-41080
url: https://lists.apache.org/thread/71wvwprtx2j2m54fovq9zr7gbm2wow2f
url: https://tomcat.apache.org/security-11.html#Fixed_in_Apache_Tomcat_11.0.0-M1
↪1
url: https://tomcat.apache.org/security-10.html#Fixed_in_Apache_Tomcat_10.1.13
url: https://tomcat.apache.org/security-9.html#Fixed_in_Apache_Tomcat_9.0.80
url: https://tomcat.apache.org/security-8.html#Fixed_in_Apache_Tomcat_8.5.93
cert-bund: WID-SEC-2024-1238
cert-bund: WID-SEC-2024-0871
cert-bund: WID-SEC-2024-0528
cert-bund: WID-SEC-2023-3070
cert-bund: WID-SEC-2023-2917
cert-bund: WID-SEC-2023-2690
cert-bund: WID-SEC-2023-2679
cert-bund: WID-SEC-2023-2182
dfn-cert: DFN-CERT-2024-3078
dfn-cert: DFN-CERT-2024-0723
dfn-cert: DFN-CERT-2024-0076
dfn-cert: DFN-CERT-2023-3070
dfn-cert: DFN-CERT-2023-3061
dfn-cert: DFN-CERT-2023-2803
dfn-cert: DFN-CERT-2023-2586
dfn-cert: DFN-CERT-2023-2568
dfn-cert: DFN-CERT-2023-2542
```

Lista aberta, sem critério de parada.

Dezenas de itens heterogêneos: **CVE**,
URL de changelog, **advisory**,
cert-bund, **dfn-cert**.

A métrica só conta omissão quando o campo sai vazio; lista incompleta não é penalizada.

RESERVA

Log Method

37–57% omitido

Log Method

Sends multiple HTTP requests and checks the responses.

Disclaimer:

- This enumeration script is provided 'as is' (means no support is given) and only providing rudimentary information about the possible enabled methods
- This script doesn't guarantee completeness or full reliability

For more reliable determination of the enabled HTTP methods please inspect the configuration of the web server manually and directly on the target host.

Details: Allowed HTTP Methods Enumeration

OID:1.3.6.1.4.1.25623.1.0.153974

Version used: 2025-02-28T05:38:49Z

Campo composto: três valores sob um rótulo.

Details, OID e Version used empilhados.

RESERVA

Product detection result

21–29% omitido

Product Detection Result

Product: cpe:/a:apache:tomcat:8.5.23

Method: Apache Tomcat Detection Consolidation

OID: 1.3.6.1.4.1.25623.1.0.107652)

Mesmo padrão: CPE, texto de detecção e OID juntos.

RESERVA

O que explica a variação entre modelos

I Adesão ao formato

Gemma 4 conforma em 64,8%: JSON inválido vira omissão.

I Um registro por vulnerabilidade

Se o bloco tem 5 vulnerabilidades e o modelo devolve 1, as outras 4 contam como omissão.

I Vulnerabilidade partida ao meio

Quando o chunk corta um registro, uns reconstroem a partir do contexto e outros descartam.

I Modo de falha

Llama 3.1 preenche na dúvida e inventa 17,4%; Gemma e Qwen3 deixam vazio.

O tamanho não prediz gpt-oss (21B) e Ministral (8B) empatam na prática.

RESERVA

Fine-tuning de segurança: por que o ganho é limitado

Campos exatos melhoram

Reconhecer CVSS, plugin ID e protocolo reduz erro de cópia.

Texto livre não melhora

A tarefa premia fidelidade à fonte, não prosa fluente de domínio.

Esquema pode desabar

Conformar ao JSON é seguir instrução, e o treino em texto de domínio enfraquece isso.

O retry não basta

Já temos retry, e o Gemma segue em 64,8%. Faltaria decodificação restrita por gramática.

No avaliador, o mesmo limite

Re-pontuar tudo com SecureBERT muda $\leq 0,21$ pp e nenhum ranking.

RESERVA

Modelo	BERTScore	Field F1	Exact	Omiss. ↓	Haluc. ↓	Schema	Sev. cov
Gemma 4 E4B	83,5	96,2	58,4	15,7	8,0	64,8	87,7
Ministral 3	93,0	98,4	87,1	2,3	8,8	96,0	87,1
Qwen3	85,0	96,8	70,0	13,5	8,9	88,1	82,1
Llama 3.1	85,5	95,6	67,4	3,2	17,4	99,1	84,1
Phi-4	91,0	98,8	90,4	2,3	8,6	100,0	88,8
DeepSeek-Coder-V2	79,4	96,8	77,1	6,7	12,0	97,7	76,0
gpt-oss	91,1	98,5	87,9	2,6	9,5	99,8	89,8
Foundation-Sec	78,8	97,8	78,5	2,7	13,3	82,1	82,1
Primus-Merged	85,2	96,8	76,4	6,7	12,1	99,5	79,3
deepseek-v4-flash (nuvem)	94,2	99,0	92,2	1,3	5,3	100,0	94,1

Verde: melhor valor entre os locais em cada coluna. Médias de 5 execuções, em %

RESERVA

Custo: taxa por relatório ou GPU própria

Local (on-premise)

Taxa por chamada **nenhuma**

Pico de VRAM **6,9 – 13,5 GB**

Exposição do relatório **zero**

Nuvem (API)

Custo por relatório **≈ US\$ 0,14**

Avaliação completa **US\$ 2,08**

Exposição do relatório **total**

Custo por relatório na nuvem varia de US\$ 0,03 a US\$ 0,30; latência e energia não são comparáveis entre GPUs

RESERVA

Modelo	GPU	VRAM	Latência	Energia	Utilização
Gemma 4 E4B	RTX 3060	9,8	82	191	93%
Ministral 3	RTX 3060	9,0	36	100	96%
Qwen3	RTX 3060	7,5	76	215	96%
Llama 3.1	RTX 5080	6,9	9	45	90%
Phi-4	RTX 5080	11,9	19	109	97%
DeepSeek-Coder-V2	RTX 5080	13,5	16	86	94%
gpt-oss	RTX 5080	12,9	13	56	89%
Foundation-Sec	RTX 5080	7,7	13	57	87%
Primus-Merged	RTX 5080	7,7	17	74	88%
deepseek-v4-flash (nuvem)	API	n/a	≈ 48*	n/a	US\$ 0,14/rei.

Verde: melhor custo-desempenho dentro de cada GPU. Latência e energia não são comparáveis entre as duas placas. *Wall-clock ponta a ponta

Limitações

Escopo

Três baselines de OpenVAS (208 vulnerabilidades).

Tenable WAS é suportado, mas ficou fora das baselines.

Medição

Latência e energia não são comparáveis entre as duas GPUs.

Cada modelo rodou em uma única placa: não foi testado se a qualidade se mantém na outra GPU.

Métrica

BERTScore mede similaridade, não correção factual.

A checagem com SecureBERT não remove essa limitação.